

Algoritmi e Protocolli per la Sicurezza

Project Work - Voto Elettronico Sicuro

GRUPPO 35



Group members:

Orefice Marco - Panico Claudio
IE22700122 - IE22700150

ANNO ACCADEMICO 2025/2026

WP1 - Modello, Attori, Avversari e Proprietà di Sicurezza	4
• 1.1 Introduzione WP1	4
• 1.2 Scelta del tipo di elezione	4
• 1.3 Attori onesti del sistema	5
• 1.4 Modello degli avversari e capacità	7
- 1.4.1 Profili degli Avversari	8
- 1.4.2 Assunzione di Non-Collusione	9
• 1.5 Proprietà di sicurezza da preservare	10
• 1.6 Priorità delle proprietà da preservare	11
• 1.7 Resilienza	12
• 1.8 Assunzioni di fiducia	13
 WP2 - Soluzione	 14
• 2.1 Introduzione	14
• 2.2 Architettura e Scelte Progettuali	14
- 2.2.1 Separazione tra Autorità di Autenticazione e Autorità Elettorale	14
- 2.2.2 Strumenti Crittografici	15
• 2.3 Fase di Setup	17
• 2.4 Fase di Autenticazione e Rilascio del Token	18
• 2.5 Fase di Votazione	20
• 2.6 Scrutinio e Pubblicazione	22
• 2.7 Verifica	23
• 2.8 Annullamento di una Scheda per Anomalia	24
 WP3 - Analisi della sicurezza	 27
• 3.1 Introduzione e metodologia di analisi	27
• 3.2 Analisi per proprietà di sicurezza	27
• 3.3 Analisi per profilo di avversario	30
• 3.4 Analisi delle modifiche alternative	31
• 3.5 Limiti dichiarati e rischio residuo	33
 WP4 — Implementazione e Prestazioni	 34
• 4.1 Obiettivo e ambiente di simulazione	34
• 4.2 Organizzazione del codice	35
• 4.3 Realizzazione degli attori e del flusso operativo	36
• 4.4 Risultati della simulazione end-to-end	38
• 4.5 Prestazioni	39
• 4.6 Limiti dell'implementazione	40

Introduzione e scopo del documento

Negli ultimi anni, la digitalizzazione si è diffusa rapidamente, andando a velocizzare e rendere più comodi diversi servizi, tra cui anche il settore elettorale, portando allo sviluppo di sistemi di voto elettronico progettati per velocizzare le operazioni di votazione e scrutinio.

Nonostante gli innumerevoli vantaggi della digitalizzazione, l'evoluzione degli attacchi informatici impone una rigida analisi dei rischi associati. Nel caso del voto elettronico, le vulnerabilità del sistema potrebbero essere sfruttate per alterare i risultati dello scrutinio o tracciare le preferenze dei votanti. Di conseguenza, questa tecnologia introduce sfide cruciali legate alla sicurezza informatica e alla tutela della privacy. Per vulnerabilità si intende una debolezza del sistema che può essere sfruttata da una minaccia.

Lo scopo di questo progetto è progettare e analizzare un protocollo crittografico che garantisca la sicurezza di una votazione elettronica per un'elezione universitaria per il rinnovo del Consiglio degli Studenti. Il progetto deve permettere di ottenere un compromesso ragionevole tra sicurezza, trasparenza ed efficienza. Il lavoro si concentra sull'utilizzo di tecniche crittografiche in grado di permettere solo agli utenti autorizzati di votare, registrare correttamente ogni voto e garantire che il risultato finale possa essere verificato senza compromettere la privacy degli elettori.

Il progetto è suddiviso in quattro work package che affrontano progressivamente la modellazione del sistema e degli avversari, la progettazione del protocollo, l'analisi delle proprietà di sicurezza e infine l'implementazione pratica del sistema in un ambiente simulato. L'obiettivo finale è dimostrare come strumenti crittografici adeguati possano contribuire alla realizzazione di sistemi elettorali digitali più sicuri, affidabili e verificabili.

WP1 - Modello, Attori, Avversari e Proprietà di Sicurezza

1.1 Introduzione WP1

In questo capitolo individueremo:

- Attori onesti, individui o entità che agiscono in conformità con le regole e le politiche stabilite che non minacciano in alcun modo la sicurezza del processo elettorale.
- Possibili Threat Model, avversari che potrebbero voler compromettere lo scrutinio sfruttando eventuali vulnerabilità del sistema. Analizzeremo strumenti e capacità tecniche in loro possesso in modo da identificare gli eventuali attacchi che il sistema potrebbe subire e di comprendere quindi come proteggersi da queste minacce.
- Proprietà di sicurezza che si vorrebbero preservare per garantire agli elettori segretezza, integrità e verificabilità del voto.

La seguente sezione non presenta alcuna soluzione tecnica o crittografica; tali aspetti saranno trattati in WP2. L'obiettivo è fornire una base chiara e non ambigua su cui fondare le scelte progettuali successive.

1.2 Scelta del tipo di elezione

Abbiamo optato per un'elezione di tipo **referendum binario**.

Il sistema sarà progettato per supportare una votazione con sole due opzioni possibili: *Sì/No*.

La scelta di un modello binario è motivata principalmente dalla minore complessità crittografica e implementativa rispetto a sistemi elettorali più articolati, come votazioni con preferenze multiple o liste ordinate. Una struttura più semplice consente infatti di ridurre il numero di vulnerabilità potenziali, in linea con il principio Economy of Mechanism il quale dice che sono preferibili meccanismi piccoli e semplici quando possibile visto che andranno a creare meno vulnerabilità.

Inoltre, una scheda binaria può essere rappresentata mediante un singolo valore logico o numerico, semplificando le operazioni di cifratura, verifica e scrutinio dei voti. Questo modello permette di concentrarsi sui principali requisiti di sicurezza di un sistema di voto elettronico, quali segretezza del voto, integrità dei dati e verificabilità del processo elettorale, riducendo al contempo i costi computazionali e la superficie di attacco del sistema.

Questa scelta consente quindi di concentrarsi sugli aspetti fondamentali della sicurezza e della correttezza del protocollo, limitando al tempo stesso la complessità crittografica e implementativa del sistema.

1.3 Attori onesti del sistema

Gli attori onesti del sistema sono le entità che seguono correttamente il protocollo, in accordo con le specifiche progettuali. Definire gli attori onesti significa specificare le loro azioni legittime all'interno del sistema, in contrapposizione al threat model che descrive invece le capacità e gli obiettivi degli avversari. Abbiamo individuato i seguenti attori onesti:

Elettore (E)

Lo studente iscritto avente diritto al voto. Gli obiettivi dell'elettore sono:

- possedere credenziali valide che ne attestino il diritto di voto;
- esprimere un singolo voto in modo anonimo;
- verificare che il proprio voto sia stato correttamente incluso nel conteggio finale;
- evitare la possibilità di essere costretto a rivelare la propria scelta a terzi.

Autorità di Autenticazione (AA)

Entità separata dall'Autorità Elettorale, responsabile esclusivamente della fase di autenticazione degli utenti. I suoi obiettivi sono:

- verificare l'identità degli elettori;
- rilasciare un token di autorizzazione pseudoanonimo o una credenziale crittografica che certifichi il diritto al voto, senza rivelare l'identità dell'elettore all'Autorità Elettorale.

Autorità Elettorale (AE)

Entità responsabile della gestione dell'elezione. I suoi obiettivi principali sono:

- ricevere, registrare e conservare in modo sicuro i voti cifrati;
- garantire l'integrità e la disponibilità delle schede durante tutta la fase di voto;
- eseguire lo scrutinio al termine della votazione;
- pubblicare i risultati in modo verificabile;
- rendere disponibili le informazioni necessarie alla verifica individuale e universale del processo.

La separazione tra Autorità di Autenticazione e Autorità Elettorale rappresenta una scelta progettuale fondamentale per garantire la divisione tra identità dell'elettore e contenuto del voto, preservando così l'anonimato del processo elettorale.

Commissione di Scrutinio (CS)

La Commissione di Scrutinio è un attore del sistema composto da più membri indipendenti, responsabile in modo collegiale della fase di decifratura e conteggio dei voti. La sua presenza aumenta la resilienza del sistema contro compromissioni interne, distribuendo le responsabilità dello scrutinio tra più soggetti in modo che nessuna singola entità detenga da sola la chiave di decifratura dei voti. Gli obiettivi della Commissione di Scrutinio sono:

- garantire la corretta esecuzione della fase di conteggio in modo distribuito, impedendo che una singola entità possa condurla autonomamente;
- impedire che un singolo membro possa influenzare o alterare l'esito dello scrutinio agendo da solo;
- contribuire alla correttezza e alla verificabilità della fase di conteggio attraverso un processo che richiede la partecipazione congiunta di un numero sufficiente di membri.

Osservatore / Verificatore Esterno

Entità esterna al sistema (ad esempio giornalisti, commissioni indipendenti o gli stessi elettori in veste di auditor) che accede alle informazioni pubbliche rese disponibili dal protocollo. Gli obiettivi dell'Osservatore / Verificatore Esterno sono:

- esaminare i dati pubblici per concorrere alla verificabilità universale del processo elettorale;
- controllare che i dati della consultazione elettorale, una volta pubblicati, non subiscano alterazioni, rimozioni o inserimenti non autorizzati;
- contribuire alla trasparenza del sistema, riducendo la dipendenza dalla fiducia esclusiva nell'Autorità Elettorale.

Pur non partecipando attivamente alle operazioni di voto o di scrutinio, l'osservatore svolge un ruolo fondamentale nel supportare la fiducia complessiva nel sistema attraverso il controllo pubblico dei dati messi a disposizione.

Certification Authority (CA)

L'ateneo assume il ruolo di Certification Authority, ovvero l'entità fidata responsabile della gestione dell'infrastruttura a chiave pubblica (PKI) del sistema. La CA opera esclusivamente nella fase di setup, precedente all'apertura delle urne. I suoi obiettivi sono:

- verificare l'identità degli attori istituzionali (AA e AE) tramite procedure amministrative dell'ateneo (autenticazione out-of-band);
- emettere certificati digitali che associano in modo verificabile l'identità di ciascun attore alla propria chiave pubblica RSA;
- rendere disponibili i certificati emessi in un repository pubblico, consultabile da tutti i partecipanti e dagli osservatori esterni.

La scelta di affidare il ruolo di CA all'ateneo è motivata dal fatto che si tratta di un'entità istituzionalmente riconosciuta e già fidata dagli studenti.

1.4 Modello degli avversari e capacità

Il Threat Model descrive il perimetro di sicurezza del sistema, stabilendo quali risorse, posizioni strategiche e capacità si ipotizza che un attaccante abbia a disposizione. Al fine di valutare la resilienza delle proprietà desiderate, gli avversari vengono suddivisi in due macro-categorie in base alle loro azioni sui canali di comunicazione:

- **Avversario Passivo:** un'entità che si limita ad ascoltare, intercettare o registrare i flussi di dati scambiati tra gli attori del sistema senza modificarli. Il suo obiettivo primario è violare la **segretezza** del voto, tentando di correlare i dati di transazione all'identità reale degli elettori.
- **Avversario Attivo:** un'entità dotata della capacità di intercettare, alterare, iniettare o eliminare messaggi sul canale. Agisce attivamente per compromettere l'**integrità** o l'**autenticità** del sistema (ad esempio, inserendo voti falsi o manipolando i record immagazzinati).

All'interno di queste capacità, il sistema modella il livello di informazione a disposizione dell'avversario attingendo ai modelli formali della crittografia, calibrati sullo scenario di una consultazione elettorale:

- **Scenario Ciphertext-Only (COA) e Known-Plaintext (KPA):** descrivono un avversario (passivo o attivo) che tenta di dedurre informazioni sulle preferenze espresse analizzando i soli dati protetti presenti nel registro pubblico, o sfruttando la conoscenza di corrispondenze note relative a consultazioni passate.
- **Scenario Chosen-Plaintext (CPA) e Chosen-Ciphertext (CCA):** descrivono il livello di minaccia più stringente per il protocollo. Poiché la chiave pubblica necessaria a proteggere i dati è nota a chiunque debba votare, si assume che l'avversario possa cifrare autonomamente messaggi di propria scelta e osservarne i cifrati risultanti (CPA). Nello scenario CCA si assume inoltre la capacità più forte di ottenere informazioni sulla decifrazione di cifrati scelti dall'avversario: l'avversario può inviare al ricevente un cifrato modificato e dedurre informazioni sul messaggio sottostante a partire dal comportamento osservabile del ricevente che lo decifra.

Si precisa che COA, KPA, CPA e CCA non identificano singoli attori del sistema, bensì i modelli formali di sicurezza che definiscono il livello di capacità concesso a un ipotetico attaccante e rispetto ai quali uno schema crittografico viene valutato robusto. Essi servono qui a calibrare il perimetro delle minacce considerate, mentre le scelte tecniche atte a soddisfare tali requisiti di robustezza sono demandate al WP2.

A queste minacce prettamente crittografiche si aggiunge il pericolo di attacchi di tipo **Denial-of-Service (DoS)**. Pur non rientrando nei modelli formali di sicurezza dei dati, il DoS rappresenta un rischio infrastrutturale critico per la **disponibilità** del servizio, volto a degradare o bloccare le operazioni di autenticazione o di raccolta dei voti, sfruttando i singoli punti di fallimento (Single Point of Failure) delle autorità centralizzate.

1.4.1 Profili degli Avversari

1. Autorità Elettorale (AE) Disonesta

- **Tipologia:** Attivo.
- **Proprietà minacciate:** Segretezza, Integrità, Correttezza.
- **Attacchi possibili:**
 - **Violazione della segretezza:** tenta di decifrare i voti per conoscere le preferenze espresse prima dello scrutinio ufficiale o, cooperando in collusione con l'AA, per associare il voto all'identità reale dell'elettore.
 - **Violazione dell'integrità:** elimina, altera o sostituisce voti cifrati prima o durante la fase di conteggio.
 - **Violazione dell'integrità selettiva:** esclude dal conteggio i voti di specifici gruppi di elettori.
 - **Violazione della correttezza:** pubblica un risultato finale non corrispondente ai voti effettivamente espressi.

2. Autorità di Autenticazione (AA) Disonesta

- **Tipologia:** Attivo.
- **Proprietà minacciate:** Segretezza, Unicità, Disponibilità.
- **Attacchi possibili:**
 - **Violazione della segretezza:** tenta di correlare il token emesso all'identità dell'elettore per ricostruire, eventualmente in collaborazione con l'AE, l'associazione diretta tra identità e voto espresso.
 - **Violazione dell'unicità:** emette token multipli per lo stesso elettore o genera token per identità fittizie o non legittimate.
 - **Violazione della disponibilità:** nega il servizio di autenticazione a elettori legittimi, impedendo l'esercizio del diritto di voto.

3. Elettore Disonesto

- **Tipologia:** Attivo.
- **Proprietà minacciate:** Unicità, Integrità.
- **Attacchi possibili:**
 - **Double voting:** tenta di esprimere più voti sfruttando l'ottenimento di token multipli.
 - **Ripudio del voto o della partecipazione:** tenta di disconoscere il voto espresso o l'avvenuto utilizzo delle proprie credenziali dopo la pubblicazione dei risultati, al fine di contestare la validità e la correttezza della sessione elettorale.
 - **Dimostrabilità del voto a terzi:** condivide dati crittografici o segreti privati per provare il contenuto del proprio voto (vendita del voto o pressioni coercitive).

4. Coercitore / Acquirente di Voti

- **Tipologia:** Attivo.
- **Proprietà minacciate:** Segretezza, Integrità (indiretta).
- **Attacchi possibili:**
 - **Acquisto del voto:** offre compensi in cambio della prova del voto espresso.
 - **Coercizione:** esercita pressioni fisiche, psicologiche o economiche per condizionare il comportamento dell'elettore in fase di voto o per sottrargli le credenziali di accesso.

5. Avversario Esterno Passivo (Eavesdropper)

- **Tipologia:** Passivo.
- **Proprietà minacciate:** Segretezza.
- **Attacchi possibili:** ascolta passivamente le comunicazioni di rete nel tentativo di estrarre informazioni sensibili dal canale o di correlare i metadati di trasmissione per violare l'anonimato degli utenti.

6. Avversario Esterno Attivo (Man-in-the-Middle)

- **Tipologia:** Attivo.
- **Proprietà minacciate:** Integrità, Segretezza, Disponibilità.
- **Attacchi possibili:**
 - **Malleabilità del cifrato:** altera un voto cifrato prima che raggiunga l'AE.
 - **Attacchi di replay:** reimmette messaggi autenticati precedentemente registrati per far conteggiare due volte lo stesso voto o sostituirne uno valido.
 - **Denial of Service:** blocca, scarta o ritarda selettivamente i messaggi di specifici elettori per influenzare indirettamente l'esito dello scrutinio.

7. Gestore dell'Infrastruttura

- **Tipologia:** Passivo/Attivo.
- **Proprietà minacciate:** Segretezza, Disponibilità.
- **Azioni malevole:**
 - **Analisi dei metadati:** accede illegittimamente ai log di rete e di sistema per correlare timestamp, indirizzi IP e volumi di traffico con i dati registrati.
 - **Denial of Service infrastrutturale:** interrompe, satura o degrada deliberatamente le risorse di rete e i server durante le operazioni di voto per impedire lo svolgimento della consultazione.

1.4.2 Assunzione di Non-Collusione

La sicurezza complessiva del sistema si fonda sull'assunzione fondamentale di **non-collusione tra AE e AA**. Questa separazione dei poteri è il pilastro architettonico: l'AE conosce i voti cifrati ma non le identità; l'AA conosce le identità ma non il contenuto dei voti. Solo la combinazione deliberata dei dati detenuti dai due soggetti consentirebbe di ricostruire l'associazione identità-voto, annullando ogni garanzia di pseudoanonimato. Tale limite, non risolvibile puramente per via crittografica in questo modello, deve essere gestito tramite audit indipendenti e trasparenza procedurale.

1.5 Proprietà di sicurezza da preservare

Il sistema di voto elettronico deve preservare le seguenti proprietà per garantire un processo elettorale sicuro, trasparente e conforme ai requisiti democratici. Non tutte le proprietà sono raggiungibili allo stesso livello simultaneamente: alcune sono in conflitto tra loro, e le scelte progettuali devono tenerne conto.

Autenticità

Il sistema deve garantire che l'accesso alla sessione di voto sia consentito esclusivamente agli studenti in possesso di credenziali universitarie valide e aventi diritto, respingendo efficacemente ogni tentativo di partecipazione da parte di soggetti non autorizzati. Il meccanismo di autenticazione deve essere robusto ma non deve compromettere l'anonimato: l'autenticazione avviene presso l'Autorità di Autenticazione, mentre il voto è raccolto dall'Autorità Elettorale, che non conosce l'identità reale dell'elettore.

Unicità del voto

Ogni elettore può esprimere al massimo un voto valido nella sessione di votazione. Qualsiasi ulteriore tentativo di voto non deve essere considerato valido dal sistema. L'unicità è strettamente legata all'autenticità: un sistema che garantisce autenticità robusta, assicurando che ogni elettore possieda credenziali uniche e non riutilizzabili, pone già buone basi per garantire anche l'unicità.

Segretezza

Il voto del singolo elettore non deve essere rivelabile, nemmeno combinando le informazioni in possesso delle autorità del sistema. Nel nostro modello questa proprietà si declina come pseudoanonimato: il legame identità-preferenza non deve essere ricostruibile da nessuna singola entità operante da sola.

Integrità

I voti espressi non devono poter essere alterati, rimossi o sostituiti dopo la loro registrazione. L'integrità garantisce che il risultato dell'elezione rifletta la volontà espressa dagli elettori. Questa proprietà si applica sia alla fase di trasmissione del voto sia alla sua custodia nel registro dei voti registrati.

Verificabilità individuale

Ogni elettore deve poter controllare autonomamente che il proprio voto sia stato correttamente incluso nel conteggio finale. La verifica individuale non deve però rivelare l'identità dell'elettore né permettere a terzi di conoscere la preferenza espressa, per evitare fenomeni di coercizione o compravendita del voto.

Verificabilità universale

Il risultato finale deve essere pubblicamente verificabile da chiunque, senza il possesso di alcuna chiave privata. Questa proprietà è fondamentale per la legittimità e la fiducia pubblica nel sistema.

Efficienza

Il protocollo deve essere utilizzabile senza costi computazionali o latenze eccessive. Gli elettori devono poter votare in tempi rapidi, l'Autorità Elettorale deve poter completare lo scrutinio in un tempo proporzionale al numero di schede, e gli osservatori devono poter verificare il risultato con facilità.

1.6 Priorità delle proprietà da preservare

La progettazione di un protocollo di voto elettronico richiede la definizione di una gerarchia rigorosa delle proprietà di sicurezza, poiché alcune di esse risultano strutturalmente conflittuali. Per stabilire tale ordine, viene adottata una scala numerica crescente da 1 a 5, dove un **numero più basso indica una priorità maggiore** e un vincolo più stringente per il sistema.

1) Autenticità e Unicità

Senza di esse l'intera elezione è invalidata: se votano soggetti non autorizzati o se uno stesso elettore può votare più volte, il risultato non ha alcun valore indipendentemente da tutto il resto.

2) Integrità

Strettamente collegata alle precedenti. I voti, una volta registrati, non devono poter essere alterati o rimossi. Senza integrità il risultato non riflette la volontà degli elettori, rendendo l'elezione priva di legittimità.

3) Segretezza

Garantisce che il voto sia libero. Un elettore che sa di poter essere identificato può essere condizionato o costretto, compromettendo il requisito democratico fondamentale del voto segreto.

4) Verificabilità universale e individuale

Importanti per la fiducia pubblica nel sistema, ma presuppongono che le proprietà precedenti siano già garantite. In particolare, la verificabilità individuale deve essere gestita con attenzione per non entrare in conflitto con la **segretezza**: la verifica riguarda esclusivamente la presenza e la validità del voto, non il suo contenuto.

5) Efficienza

Requisito infrastrutturale: grave se violato durante la fase di voto, ma non compromette direttamente la validità dei voti già registrati.

1.7 Resilienza

Per resilienza si intende la capacità del protocollo di mantenere intatte le proprie garanzie funzionali e di sicurezza anche in presenza di comportamenti ostili o deviazioni rispetto al comportamento onesto. In un sistema di voto elettronico, tuttavia, non tutte le proprietà desiderate possono essere preservate simultaneamente a fronte di qualsiasi tipologia di attacco. Diventa quindi necessario mappare con precisione quali tutele il protocollo sia in grado di blindare matematicamente e sotto quali specifiche assunzioni di fiducia, distinguendole chiaramente dai limiti strutturali e dai rischi residui accettati.

Le proprietà garantite dal protocollo sono:

- **Integrità del registro pubblicato**, garantita in presenza di un avversario attivo a condizione che le chiavi rimangano riservate al legittimo detentore. Un avversario che intercetta e modifica un voto in transito, o che tenta di iniettarne uno fraudolento, viene rilevato prima che il voto venga accettato; allo stesso modo, una volta registrati, i voti non possono essere alterati o rimossi a posteriori senza che la cosa risulti rilevabile. La garanzia decade se le chiavi vengono compromesse. Va però distinta dall'integrità del conteggio, che in questo modello non è garantita in modo incondizionato. L'Autorità Elettorale, modellata come potenzialmente disonesta, potrebbe escludere voti prima della loro registrazione oppure pubblicare un risultato aggregato non corrispondente al reale contenuto delle schede registrate. Questo limite non è risolvibile con i soli strumenti considerati nel modello ed è mitigato, non eliminato, dalla verificabilità individuale (che permette a ciascun elettore di rilevare la mancata inclusione del proprio voto), dalla trasparenza procedurale, dalla presenza di osservatori esterni e dalla distribuzione della fase di conteggio tra i membri della Commissione di Scrutinio.
- **Autenticità**, garantita dal modello: solo un elettore in possesso di credenziali universitarie valide può ottenere un token dall'AA. Un avversario esterno privo di tali credenziali non può partecipare all'elezione. La garanzia vale sotto l'assunzione che la CA non sia compromessa e che l'AA si comporti correttamente.
- **Verificabilità individuale e universale**, garantita attraverso la pubblicazione di un impegno pubblico e non falsificabile sui voti registrati, controllabile da chiunque in modo efficiente rispetto al numero di voti. Un avversario che alteri anche un solo voto nel registro invalida tale impegno, rendendo l'alterazione rilevabile. La garanzia vale sotto l'assunzione che l'autorità si impegni in modo vincolante sul registro prima della pubblicazione e che tale impegno non venga compromesso.
- **Unicità**, garantita crittograficamente sotto la duplice assunzione dichiarata: che l'AA non emetta token multipli per lo stesso elettore e che l'AE gestisca correttamente il registro dei token consumati. Un avversario esterno che tenti di riutilizzare una credenziale già presentata viene rigettato dal sistema. La garanzia decade se una di queste assunzioni di fiducia viene violata.
- **Segretezza**, garantita contro un avversario che osserva il traffico o interagisce attivamente con il sistema, a condizione che nessuna singola entità disponga sia dell'identità dell'elettore sia del suo voto cifrato. La garanzia decade in caso di collusione tra AA e AE, scenario escluso dall'assunzione di non-collusione dichiarata o in caso di compromissione della CA.

Le proprietà che invece rischiano di non essere garantite in presenza di attacchi sono:

- **La resistenza alla coercizione** non è garantibile con i meccanismi considerati in questo modello. Il voto elettronico avviene in un ambiente non fisicamente controllato: un avversario che si trovi in presenza dell'elettore al momento del voto, o che eserciti pressione prima o dopo la votazione, può costringere l'elettore a votare in un determinato modo o a rivelare la propria preferenza. Questa proprietà costituisce un limite strutturale intrinseco del voto elettronico in ambienti non controllati, indipendentemente dal protocollo adottato.

1.8 Assunzioni di fiducia

In qualsiasi sistema crittografico è necessario dichiarare esplicitamente le componenti di cui ci si fida, poiché nessun meccanismo crittografico può eliminare completamente la dipendenza da entità fidate. Le assunzioni che seguono identificano i limiti del modello e le condizioni sotto cui le proprietà di sicurezza descritte nella sezione precedente sono garantite. Per questo motivo, assumiamo che:

- **Il sistema di autenticazione istituzionale sia affidabile:** si assume che l'ateneo disponga di un'infrastruttura di gestione delle identità in grado di attestare in modo certo lo status degli studenti aventi diritto al voto. La legittimità degli elettori è determinata dall'università in quanto entità fidata ed esterna al sistema elettorale propriamente detto.
- **L'Autorità di Certificazione (CA) sia onesta:** la CA non emette certificati fraudolenti e le sue procedure amministrative di verifica dell'identità sono considerate prive di falle. La fiducia nella CA si basa sulla sua reputazione istituzionale e sulla competenza operativa, non su verifiche crittografiche interne al protocollo.
- **AA e AE non colludano:** si assume rigorosamente che l'Autorità di Autenticazione e l'Autorità Elettorale non condividano tra loro i rispettivi dati per ricostruire l'associazione diretta tra identità e preferenza. L'AA conosce l'identità civile degli studenti ma non il contenuto dei voti; l'AE riceve i voti protetti ma non possiede elementi per risalire alle identità reali.
- **L'AA agisca correttamente nel rilascio delle credenziali:** l'autorità non emette token multipli per lo stesso elettore e si astiene dal generare token per identità fittizie o non aventi diritto.
- **L'AE gestisca correttamente il registro dei token consumati:** l'autorità elettorale opera in modo conforme alle regole, rifiutando token già utilizzati per impedire il double voting e scartando qualsiasi voto che non sia accompagnato da una credenziale di autorizzazione valida.
- **Il Bulletin Board sia accessibile e trasparente:** il portale web o la piattaforma digitale utilizzata per la pubblicazione dei risultati sia costantemente accessibile a elettori e osservatori esterni. Tale infrastruttura **non è assunta come fidata** per l'integrità dei dati: l'autenticità e l'immutabilità delle informazioni pubblicate non dipendono dalla sicurezza del canale di distribuzione, ma dall'impegno crittografico vincolante assunto dall'autorità prima della pubblicazione.

WP2 - Soluzione

2.1 Introduzione

In questo capitolo viene presentato il protocollo crittografico che realizza il sistema di voto elettronico descritto nel WP1. Mentre nel capitolo precedente ci siamo limitati a definire il modello del sistema tra cui gli attori, le loro azioni legittime, il modello degli avversari e le proprietà di sicurezza da preservare senza introdurre alcuna soluzione tecnica, questo capitolo specifica le scelte progettuali concrete e gli strumenti crittografici impiegati per soddisfare tali proprietà.

L'obiettivo è descrivere un protocollo che, attraverso l'uso combinato di cifratura a chiave pubblica, firme digitali, codici di autenticazione dei messaggi e strutture di integrità basate su hash, garantisca le proprietà di autenticità, unicità, segretezza, integrità e verificabilità individuate nel WP1.

La progettazione assume come punto di partenza un'ipotesi operativa già dichiarata tra le assunzioni di fiducia del WP1: l'elettore accede al sistema di ateneo essendo già autenticato tramite SPID, CIE o le proprie credenziali universitarie. Il protocollo descritto in questo capitolo non si occupa quindi della fase di login iniziale dell'utente presso i servizi di ateneo, bensì di tutto ciò che avviene a valle di tale accesso: la distribuzione delle chiavi, il rilascio di un token pseudoanonimo che certifichi il diritto al voto, la trasmissione sicura della scheda, la sua registrazione verificabile e la pubblicazione di un risultato controllabile da chiunque.

2.2 Architettura e Scelte Progettuali

Il protocollo è costruito attorno a due principi architetturali fondamentali, entrambi finalizzati a soddisfare le proprietà di sicurezza definite nel WP1. Il primo è la separazione dei poteri tra l'entità che autentica gli elettori e l'entità che raccoglie i voti, necessaria a garantire la segretezza intesa come pseudoanonimato. Il secondo è l'impiego di una catena di strumenti crittografici che coprono, in fasi distinte, l'autenticità della comunicazione, la riservatezza del contenuto, l'integrità in transito e l'integrità del registro pubblicato.

L'idea di fondo è che nessuna singola entità del sistema debba disporre contemporaneamente dell'identità dell'elettore e del contenuto del suo voto. Questo obiettivo viene perseguito sul piano architetture tramite la separazione AA/AE, e sul piano crittografico tramite l'uso mirato di ciascuno strumento solo dove serve, evitando di concentrare informazioni sensibili in un unico punto del sistema.

2.2.1 Separazione tra Autorità di Autenticazione e Autorità Elettorale

La separazione tra Autorità di Autenticazione (AA) e Autorità Elettorale (AE) costituisce il pilastro dell'intero protocollo. L'AA verifica l'identità dell'elettore e ne attesta il diritto al voto, ma non viene mai a conoscenza del contenuto della scheda; l'AE riceve e registra i voti, ma

non conosce l'identità di chi li ha espressi. Solo la combinazione deliberata delle informazioni detenute dalle due autorità consentirebbe di ricostruire l'associazione tra identità e preferenza, ed è proprio questa combinazione che l'assunzione di non-collusione, dichiarata nel WP1, esclude.

Il meccanismo che concretizza questa separazione è il rilascio di un token pseudoanonimo. Dopo aver verificato l'identità dell'elettore, l'AA emette un token crittografico che certifica il diritto al voto senza contenere alcun riferimento all'identità del titolare. L'elettore presenta questo token all'AE al momento del voto: l'AE è in grado di verificare che il token è valido e non è già stato utilizzato, ma non può risalire da esso all'identità dell'elettore. In questo modo l'AA conosce «chi ha diritto di votare» ma non «cosa ha votato», mentre l'AE conosce «quali voti sono stati espressi» ma non «da chi». È importante precisare che la non-tracciabilità del token non deriva da una proprietà crittografica intrinseca: l'AA, emettendo il token, ne conosce il valore e potrebbe in linea di principio comunicarlo all'AE, bensì poggia sull'assunzione di non-collusione dichiarata nel WP1. Per questa ragione si parla di pseudoanonimato e non di anonimato in senso forte perché ci fidiamo della non-collusione tra AA e AE.

Questa architettura ha una conseguenza diretta sul modo in cui viene firmato il voto, discussa nelle sezioni successive: poiché la segretezza richiede che il legame identità-preferenza non sia ricostruibile, l'elettore non firma la propria scheda con una chiave a sé riconducibile. La firma digitale che protegge il registro dei voti è immessa dall'AE, non dall'elettore.

2.2.2 Strumenti Crittografici

Il protocollo impiega un insieme di strumenti crittografici, ciascuno assegnato a una funzione precisa. La scelta di limitare ogni strumento al ruolo per cui è necessario risponde al principio di Economy of Mechanism: meccanismi piccoli e mirati riducono la superficie di attacco.

Cifratura a chiave pubblica (RSA con OAEP). Il contenuto del voto viene cifrato con la chiave pubblica dell'Autorità Elettorale mediante RSA. Per la cifratura si adotta lo schema di padding OAEP, che rende lo schema resistente ad attacchi su cifrari scelti. Questo garantisce la segretezza del voto in transito e in custodia: solo chi detiene la chiave privata di decifratura può recuperare il contenuto in chiaro della scheda.

Firma digitale RSA. L'Autorità Elettorale firma con la propria chiave privata la radice dell'albero che riassume tutti i voti registrati, prima della sua pubblicazione. Chiunque, disponendo della chiave pubblica certificata dell'AE, può verificare tale firma. Questo lega in modo non ripudiabile il registro pubblicato all'AE e impedisce che la radice venga sostituita da terzi dopo la chiusura delle urne, eliminando la necessità di riporre fiducia nel solo luogo di pubblicazione.

Codice di autenticazione dei messaggi (HMAC) in modalità Encrypt-then-MAC. La trasmissione del voto dall'elettore all'AE è protetta da un tag HMAC, secondo lo schema Encrypt-then-MAC. La chiave simmetrica necessaria al calcolo del tag è generata dall'elettore e trasmessa all'AE cifrata con la chiave pubblica dell'AE, secondo lo schema di distribuzione di chiavi tramite chiave pubblica: in questo modo la chiave è condivisa

unicamente tra elettore e AE, mentre l'AA non ne viene mai a conoscenza, preservando la separazione dei poteri. Il tag è calcolato non sul solo cifrato, ma sull'insieme costituito dal cifrato, dal token e dal nonce di sessione, così da vincolare in modo non falsificabile questi elementi allo specifico messaggio di voto. Questo meccanismo garantisce l'integrità e l'autenticità del messaggio durante il transito: un avversario attivo che alteri il cifrato, tenti di abbinare il token a un voto diverso o riproponga un messaggio già inviato viene rilevato, perché non è in grado di produrre un tag valido. Il tag protegge dunque una fase distinta da quella coperta dalla firma dell'AE: l'HMAC tutela il singolo messaggio in transito verso l'AE, la firma tutela l'integrità del registro complessivo dopo la registrazione.

Funzione hash crittografica (SHA-256) e albero di Merkle. L'integrità del registro dei voti e la verificabilità del processo sono realizzate tramite un albero di Merkle costruito sui voti registrati, utilizzando SHA-256 come funzione hash. Ogni voto registrato corrisponde a una foglia dell'albero; la radice costituisce un impegno crittografico compatto sull'intero insieme dei voti. L'alterazione anche di un solo voto modifica la radice, rendendo la manomissione rilevabile. La struttura ad albero consente inoltre a ciascun elettore di verificare l'inclusione del proprio voto fornendo solo il cammino dalla foglia alla radice, in numero di passi logaritmico rispetto al numero totale di voti, in linea con il requisito di efficienza.

Infrastruttura a chiave pubblica (PKI) e certificati X.509. Le chiavi pubbliche degli attori istituzionali (AA e AE) sono certificate dalla Certification Authority, ruolo assunto dall'ateneo. I certificati X.509 associano in modo verificabile l'identità di ciascun attore alla rispettiva chiave pubblica RSA e sono resi disponibili in un repository pubblico. Questo consente a elettori e osservatori di ottenere le chiavi pubbliche autentiche delle autorità senza doverle scambiare direttamente, e di verificare la firma dell'AE risalendo alla CA come radice di fiducia.

Challenge-response con nonce. Per proteggere lo scambio dei messaggi dagli attacchi di replay, le fasi interattive del protocollo adottano uno schema challenge-response: la parte che attende un messaggio fresco invia preventivamente un nonce e richiede che la risposta successiva contenga il valore corretto del nonce. Questo impedisce a un avversario di reimmettere messaggi autenticati precedentemente registrati per far conteggiare due volte lo stesso voto.

Condivisione del segreto a soglia (schema (t,n)). Per proteggere la fase di decifratura contro le compromissioni interne, la chiave privata di decifratura dell'Autorità Elettorale è suddivisa tra i membri della Commissione di Scrutinio mediante uno schema di secret sharing a soglia (t,n) . Il segreto viene suddiviso in n quote distribuite ai membri della commissione, in modo tale che siano necessarie almeno t quote per ricostruirlo, mentre un numero inferiore di quote non fornisce alcuna informazione sul segreto. In questo modo nessun singolo membro è in grado di decifrare autonomamente i voti, e la decifratura può avvenire solo come operazione congiunta di un numero sufficiente di membri. Lo schema tollera inoltre l'indisponibilità di alcuni membri, purché ne resti operativo almeno un numero pari alla soglia.

Strumento Crittografico	Ambito di Applicazione	Proprietà di Sicurezza Garantita
RSA con OAEP	Contenuto della scheda elettorale	Segretezza
HMAC (Encrypt-then-MAC)	Trasmissione del voto verso l'AE; binding tra cifrato, token e nonce	Autenticità e integrità in transito, vincolo token-voto
Nonce (Challenge-Response)	Scambio interattivo dei messaggi	Protezione Anti-Replay
SHA-256 + Albero di Merkle	Struttura del registro dei voti	Integrità globale e Verificabilità
Firma Digitale RSA	Radice del registro pubblico	Non ripudiabilità
Certificati X.509 (PKI)	Chiavi pubbliche delle Autorità	Fiducia e identità verificabile
Secret Sharing a soglia (t, n)	chiave privata di decifratura dell'AE	Segretezza

2.3 Fase di Setup

La fase di setup precede l'apertura delle urne e ha lo scopo di predisporre le chiavi crittografiche e i certificati necessari al funzionamento del protocollo. In questa fase opera la Certification Authority, ruolo assunto dall'ateneo, mentre gli elettori non sono ancora coinvolti. Al termine del setup ogni attore istituzionale dispone delle proprie chiavi e i partecipanti sono in grado di reperire in modo autentico le chiavi pubbliche delle autorità.

Generazione delle coppie di chiavi. L'Autorità di Autenticazione e l'Autorità Elettorale generano ciascuna la propria coppia di chiavi RSA, composta da una chiave privata mantenuta segreta e dalla corrispondente chiave pubblica destinata a essere certificata e resa pubblicamente disponibile. La chiave privata dell'AE assolve a due funzioni distinte: la decifratura dei voti ricevuti, cifrati dagli elettori con la corrispondente chiave pubblica, e la firma della radice dell'albero di Merkle al momento della pubblicazione. La chiave privata dell'AA è impiegata per emettere i token che attestano il diritto al voto.

Certificazione delle chiavi pubbliche. La Certification Authority verifica l'identità degli attori istituzionali tramite procedure amministrative dell'ateneo, ossia attraverso un'autenticazione out-of-band che non si fonda su meccanismi crittografici ma sulla competenza operativa e sulla reputazione dell'ente. Verificata l'identità di AA e AE, la CA emette per ciascuno un certificato X.509 che, tramite la firma della CA, associa in modo verificabile l'identità dell'attore alla rispettiva chiave pubblica RSA. I certificati emessi vengono pubblicati in un repository accessibile a tutti i partecipanti e agli osservatori esterni, che possono verificarne l'autenticità disponendo della chiave pubblica della CA come radice di fiducia.

Distribuzione della radice di fiducia. Affinché elettori e osservatori possano verificare i certificati emessi dalla CA, la chiave pubblica della CA stessa deve essere nota ai partecipanti come radice di fiducia. Coerentemente con quanto stabilito nel WP1, la fiducia

nella CA non deriva da un meccanismo crittografico ma dal suo riconoscimento istituzionale: la chiave pubblica della CA è resa disponibile dall'ateneo come ancora di fiducia del sistema. A partire da essa, qualunque partecipante può validare i certificati di AA e AE verificando direttamente la firma apposta dalla CA.

Predisposizione della Commissione di Scrutinio. La fase di setup comprende anche la suddivisione della chiave privata di decifratura dell'AE tra i membri della Commissione di Scrutinio mediante lo schema di secret sharing a soglia (t,n) . La chiave non viene mantenuta integra da un'unica entità, bensì suddivisa in n quote distribuite ai membri della commissione, con la soglia t fissata in modo da bilanciare la riservatezza, che richiede una soglia sufficientemente alta da impedire decifrazioni non autorizzate, e la disponibilità, che richiede una soglia non troppo elevata, così da consentire la ricostruzione anche in caso di indisponibilità di alcuni membri.

Al termine della fase di setup il sistema dispone di tutte le chiavi e i certificati necessari. Gli elettori, una volta avviata la sessione di voto, potranno ottenere in modo autentico la chiave pubblica dell'AE per cifrare la propria scheda e la chiave pubblica dell'AA per verificare la validità del token ricevuto.

2.4 Fase di Autenticazione e Rilascio del Token

In questa fase l'elettore si rivolge all'Autorità di Autenticazione per ottenere il token che ne attesta il diritto al voto. È la fase in cui si realizza concretamente la separazione tra identità e contenuto del voto: l'AA verifica «chi» ha diritto di votare e rilascia un token che l'elettore presenterà successivamente all'AE, senza che da tale token sia possibile risalire all'identità dell'elettore.

Presupposto. Come stabilito tra le assunzioni del WP1, l'elettore accede al sistema essendo già autenticato presso i servizi di ateneo tramite SPID, CIE o le proprie credenziali universitarie. L'AA dispone quindi di un canale autenticato con l'elettore, sul quale è certa dell'identità di chi sta interagendo. Su questo canale autenticato l'AA verifica che l'elettore figuri tra gli aventi diritto e che non abbia già ricevuto un token per la sessione corrente.

Rilascio del token. Verificato il diritto al voto, l'AA emette un token che certifica tale diritto. Il token è firmato dall'AA con la propria chiave privata e include un identificativo univoco che lo distingue da ogni altro token emesso: chiunque, disponendo della chiave pubblica certificata dell'AA, può verificarne la validità, ma il token non contiene alcun riferimento all'identità dell'elettore. L'identificativo univoco è ciò che consentirà all'AE, in fase di voto, di marcare il token come consumato e di rilevare eventuali tentativi di riutilizzo. L'AE, ricevendolo, potrà quindi accertare che si tratta di un token autentico, emesso dall'AA e non contraffatto, senza però poter risalire all'elettore che lo possiede.

Affinché la separazione regga, è essenziale che il token non costituisca un identificatore correlabile all'identità. L'AA registra di aver emesso un token per quell'elettore, così da impedire l'emissione di token multipli alla stessa persona (condizione necessaria a garantire l'unicità del voto), ma non conserva nei propri registri l'associazione tra identità e valore del

token consegnato: il dato che l'AE potrà osservare al momento del voto non è dunque riconducibile, sulla base dei registri delle due autorità, all'elettore che lo ha ricevuto. Questa misura riduce la superficie di una possibile collusione ma non la elimina: come precisato in 2.2.1, l'AA conosce comunque il valore del token al momento dell'emissione e potrebbe in linea di principio comunicarlo all'AE. La non-tracciabilità non deriva quindi da una proprietà crittografica intrinseca del token, ma poggia sull'assunzione di non-collusione tra AA e AE: le due autorità non condividono le rispettive informazioni e, per questo, dal token non è possibile risalire all'elettore. In questo modo l'AA conosce «a chi» ha rilasciato un token ma non «quale voto» quel token servirà a esprimere, mentre l'AE osserva «quali token» sono stati usati per votare ma non «da chi» provengono.

Vincolo tra token e chiave di integrità. L'integrità del voto in transito sarà protetta, nella fase successiva, da un tag HMAC calcolato con una chiave simmetrica nota unicamente all'elettore e all'AE. Tale chiave non è distribuita dall'AA: è l'elettore stesso a generarla e a trasmetterla all'AE, al momento del voto, incapsulata con la chiave pubblica dell'AE mediante RSA con padding OAEP, secondo lo schema di distribuzione di chiavi simmetriche tramite cifratura a chiave pubblica. In questo modo la chiave resta riservata tra elettore e AE, e l'AA non vi ha mai accesso, preservando la separazione dei poteri. Affinché tale chiave sia legata in modo non falsificabile al token, già in fase di richiesta l'elettore genera la propria chiave simmetrica e ne comunica all'AA l'impronta crittografica, ottenuta tramite SHA-256. L'AA include questa impronta tra i dati firmati del token: il token così emesso vincola, oltre al diritto di voto, anche la specifica chiave di integrità del legittimo richiedente, senza che l'AA venga mai a conoscenza del valore della chiave né del contenuto del voto. In fase di voto l'AE, dopo aver verificato la firma del token, decifrerà la chiave ricevuta con la propria chiave privata e ne confronterà l'impronta SHA-256 con quella contenuta nel token, accertando che il token sia utilizzato esclusivamente dall'elettore a cui è stato rilasciato.

Questa scelta è coerente con quanto stabilito nel WP1, dove l'integrità è garantita a condizione che le chiavi restino riservate al legittimo detentore: poiché la chiave di integrità non è conosciuta dall'AA (modellata come potenzialmente disonesta) il tag HMAC protegge il voto in transito anche rispetto a un'AA che tentasse di alterarlo o sostituirlo, e non solo rispetto agli avversari esterni. Il vincolo tra token e chiave impedisce inoltre che un avversario, intercettato il pacchetto di un elettore onesto, possa riutilizzarne il token allegandolo a un voto proprio: non disponendo della chiave originale impegnata nel token, qualunque sostituzione verrebbe rilevata dall'AE.

Protezione dagli attacchi di replay. Lo scambio è protetto da uno schema challenge-response basato su nonce, in modo che l'AA accetti solo richieste fresche e che un avversario non possa reimmettere una richiesta di token precedentemente registrata per ottenere un secondo token. La parte che attende il messaggio invia preventivamente un nonce e richiede che la risposta contenga il valore corretto, scartando i messaggi che non lo soddisfano. Si noti che questo meccanismo protegge la freschezza del singolo scambio interattivo, mentre l'unicità del voto nel tempo è garantita separatamente dal registro dei token consumati gestito dall'AE.

Al termine di questa fase l'elettore dispone del token pseudoanonimo firmato dall'AA, della chiave pubblica dell'AE necessaria a cifrare la scheda e a incapsulare la chiave di integrità, e della chiave simmetrica da lui generata, la cui impronta è già vincolata nel token. Con questi elementi può procedere alla fase di votazione.

2.5 Fase di Votazione

In questa fase l'elettore esprime la propria preferenza e la trasmette all'Autorità Elettorale. La scheda viene cifrata per garantirne la segretezza, protetta da un tag di integrità per impedirne l'alterazione in transito e accompagnata dal token che ne attesta la legittimità senza rivelare l'identità del votante.

Apertura dello scambio. Prima della trasmissione del voto, l'AE invia all'elettore un nonce di sessione, secondo lo stesso schema challenge-response descritto in 2.4. L'elettore dovrà includere tale nonce nel calcolo del tag di integrità, così che l'AE accetti esclusivamente messaggi freschi e possa scartare qualunque tentativo di reimmettere un messaggio di voto precedentemente registrato.

Composizione della scheda. Trattandosi di un referendum binario, la preferenza dell'elettore è rappresentata da un singolo valore logico corrispondente alle due opzioni possibili (Sì/No). La cifratura tramite RSA con padding OAEP introduce componenti casuali nel processo, garantendo che due voti identici non producano lo stesso cifrato e non siano quindi distinguibili o correlabili da un osservatore esterno.

Cifratura del voto. L'elettore cifra la scheda con la chiave pubblica dell'Autorità Elettorale mediante RSA con padding OAEP, ottenendo il cifrato c . Solo l'AE, la cui chiave privata di decifratura è suddivisa tra i membri della Commissione di Scrutinio secondo lo schema a soglia, potrà recuperare il contenuto in chiaro del voto attraverso la ricostruzione collegiale della chiave. Da questo momento il contenuto della preferenza è protetto: un avversario che intercetti c non è in grado di dedurre la preferenza. L'adozione di OAEP rende inoltre lo schema robusto rispetto al modello di minaccia a cifrato scelto e, introducendo una componente casuale nella cifratura, garantisce che due voti identici non producano lo stesso cifrato, proprietà essenziale in un referendum binario con due soli plaintext possibili.

Incapsulamento della chiave di integrità. L'elettore incapsula la chiave simmetrica da lui generata, la stessa la cui impronta è vincolata nel token, cifrandola con la chiave pubblica dell'AE mediante RSA con padding OAEP. Si ottiene così l'elemento k_{enc} , che consente al solo AE di recuperare la chiave necessaria a verificare il tag di integrità. Coerentemente con la separazione dei poteri, l'AA non viene mai a conoscenza di questa chiave.

Calcolo del tag di integrità (Encrypt-then-MAC). L'elettore calcola un tag HMAC t utilizzando la chiave simmetrica da lui generata, applicandolo all'insieme costituito dal cifrato, dal token e dal nonce della sessione: $t = \text{HMAC}_k(c \parallel \text{token} \parallel \text{nonce})$.

Si adotta dunque lo schema Encrypt-then-MAC, con il tag calcolato sul cifrato e non sul testo in chiaro. Estendere il calcolo del tag anche al token e al nonce realizza un legame crittografico tra questi elementi e lo specifico messaggio di voto: il token non viaggia come

dato indipendente affiancato al voto, ma è vincolato ad esso dal medesimo tag. Qualunque alterazione di c , qualunque tentativo di sostituire il token o di abbinarlo a un cifrato diverso, e qualunque riproposizione del messaggio con un nonce non valido, vengono rilevati dall'AE, poiché un avversario privo della chiave di integrità non è in grado di produrre un tag valido. La chiave, a sua volta, è vincolata al token tramite l'impronta firmata dall'AA descritta in 2.4: l'avversario non può quindi sostituirla con una propria senza che il confronto con l'impronta fallisca.

Messaggio di voto. L'elettore trasmette all'AE una quadrupla composta dal cifrato c , dal tag t , dal token rilasciato dall'AA e dalla chiave di integrità incapsulata k_{enc} . Il token resta esterno al cifrato del voto poiché l'AE deve poterne verificare la validità e l'unicità senza dover e poter conoscere anticipatamente il contenuto del voto. Pur restando esterno al cifrato, il token è comunque protetto dal tag HMAC che lo include nel proprio calcolo, ed è perciò legato in modo non falsificabile a questo specifico messaggio. La presenza della chiave incapsulata come quarto elemento non compromette lo pseudoanonimato: k_{enc} è cifrata con la chiave pubblica dell'AE, dunque solo l'AE può aprirla; la chiave non contiene alcun riferimento all'identità dell'elettore. La trasmissione è inoltre protetta dallo schema challenge-response: il nonce inviato dall'AE all'apertura dello scambio è incluso nel calcolo del tag, dunque un messaggio di voto registrato in precedenza, recante un nonce ormai non più valido, viene scartato dall'AE.

Verifiche dell'AE alla ricezione. Ricevuto il messaggio, l'AE esegue una sequenza di controlli prima di accettare il voto:

1. Verifica la validità del token, controllando tramite la chiave pubblica certificata dell'AA che si tratti di un token autentico e non contraffatto.
2. In secondo luogo verifica che il token non sia già presente nel registro dei token consumati: se lo fosse, il voto viene rigettato, impedendo il doppio voto e il riutilizzo del token.
3. Dopo decifra con la propria chiave privata la chiave di integrità incapsulata k_{enc} e ne confronta l'impronta SHA-256 con quella firmata all'interno del token: se le due impronte non coincidono, la chiave non è quella vincolata al token e il voto viene scartato, neutralizzando i tentativi di riuso del token da parte di un avversario.
4. Infine verifica il tag HMAC t sull'insieme costituito da cifrato, token e nonce; se il tag non è valido, il messaggio è stato alterato in transito o non proviene dal legittimo detentore della chiave, e il voto viene scartato.

Solo se tutti i controlli hanno esito positivo l'AE registra il voto: marca il token come consumato e registra il voto tra i voti accettati: la foglia dell'albero di Merkle è costituita dalla tripla (cifrato c , tag, pseudonimo del token), che ne fissa in modo immutabile non solo il contenuto cifrato ma anche il tag di integrità e il riferimento al token consumato. La decifrazione del voto non avviene in questa fase, ma è rimandata allo scrutinio.

Garanzia di unicità. L'unicità del voto è assicurata dalla combinazione di due controlli su due autorità distinte: l'AA impedisce che a uno stesso elettore vengano rilasciati token multipli, mentre l'AE impedisce che uno stesso token venga utilizzato più di una volta. Nessuna delle due autorità, da sola, dispone delle informazioni necessarie a violare la segretezza, ma insieme i due controlli garantiscono che ogni avente diritto possa esprimere al più un voto valido.

2.6 Scrutinio e Pubblicazione

Conclusa la fase di voto, l'Autorità Elettorale chiude le urne e procede allo scrutinio. Questa fase trasforma l'insieme dei voti cifrati e registrati in un risultato pubblicamente verificabile, senza compromettere la segretezza dei singoli voti.

Chiusura delle urne e costruzione dell'impegno. Al termine del periodo di votazione, l'AE dispone dell'insieme dei voti registrati, ciascuno in forma cifrata, e del registro dei token consumati. Su questo insieme l'AE costruisce un albero di Merkle utilizzando SHA-256: ogni voto registrato corrisponde a una foglia, e la radice dell'albero costituisce un impegno crittografico compatto sull'intero insieme dei voti. La radice fissa in modo immutabile il contenuto del registro nel momento della chiusura: qualunque successiva alterazione, rimozione o sostituzione anche di un solo voto produrrebbe una radice diversa e sarebbe quindi rilevabile.

Firma della radice. L'AE firma la radice dell'albero di Merkle con la propria chiave privata RSA. La firma lega in modo non ripudiabile la radice all'AE e impedisce che, dopo la chiusura delle urne, la radice pubblicata venga sostituita da terzi: chiunque disponga della chiave pubblica certificata dell'AE può verificare che la radice è autentica e prodotta dall'AE. La firma sulla radice elimina la necessità di fidarsi della sicurezza del portale di pubblicazione. Qualora la radice pubblicata non fosse firmata dall'AE, o presentasse una firma non valida (ad esempio a seguito di un attacco hacker al sito), il sistema la identificherebbe subito come illegittima.

Decifratura dei voti. Per produrre il conteggio, i voti registrati devono essere decifrati con la chiave privata di decifratura dell'AE. Tale chiave non è detenuta integralmente da un'unica entità ma è suddivisa tra i membri della Commissione di Scrutinio secondo lo schema a soglia (t,n) : la decifratura avviene quindi solo come operazione congiunta di almeno t membri, che ricostruiscono la chiave a partire dalle proprie quote. In questo modo nessun singolo membro è in grado di decifrare autonomamente i voti, e la fase di conteggio risulta protetta contro la compromissione di una singola entità.

Conteggio e pubblicazione del risultato. Decifrati i voti, l'AE calcola il risultato del referendum come conteggio aggregato delle due opzioni, ottenendo il numero complessivo di preferenze per il Sì e per il No. Viene pubblicato esclusivamente il risultato aggregato, insieme alla radice dell'albero di Merkle firmata dall'AE. Non viene pubblicata alcuna lista che associ identità degli studenti ai voti, né alcun elenco che legghi i singoli voti decifrati alle rispettive identità: la pubblicazione del solo aggregato, unita alla separazione AA/AE e

all'assenza nel registro di riferimenti all'identità, preserva la segretezza del voto anche dopo lo scrutinio.

Limite di verificabilità del conteggio. Va precisato che il legame tra le foglie cifrate dell'albero e il conteggio aggregato pubblicato non è, in questo modello, verificabile crittograficamente da terzi: l'AE decifra i voti e ne annuncia l'aggregato, ma non è possibile dimostrare pubblicamente che il conteggio sia valido. Come già anticipato tra le assunzioni del WP1, questo limite non è eliminabile, ma solo attenuabile. Diversi elementi concorrono ad attenuarlo:

- la verificabilità individuale, grazie alla quale ciascun elettore può accorgersi se il proprio voto è stato omesso dal conteggio;
- la trasparenza delle procedure;
- il controllo esercitato da osservatori esterni;
- la decifrazione, che non è affidata a un'unica entità ma ricostruita congiuntamente dai membri della Commissione di Scrutinio.

La pubblicazione del risultato aggregato accompagnato dalla radice firmata costituisce il punto di partenza della fase di verifica: a partire da questi elementi pubblici, gli elettori e gli osservatori possono controllare rispettivamente l'inclusione del proprio voto e la coerenza complessiva del processo.

2.7 Verifica

La fase di verifica consente di controllare la correttezza del processo elettorale a partire dalle sole informazioni pubbliche, senza il possesso di alcuna chiave privata. Coerentemente con le proprietà definite nel WP1, si distinguono due livelli di verifica: la verifica individuale, riservata al singolo elettore che controlla l'inclusione del proprio voto, e la verifica universale, accessibile a chiunque per controllare la coerenza complessiva del risultato. Entrambe si fondano sugli elementi pubblicati al termine dello scrutinio: il risultato aggregato e la radice dell'albero di Merkle firmata dall'AE.

Verifica individuale. Ogni elettore deve poter controllare autonomamente che il proprio voto sia stato correttamente incluso nel conteggio, senza per questo rivelare la propria identità né il contenuto della preferenza espressa. La verifica si basa sulla struttura dell'albero di Merkle: l'elettore, che conosce il cifrato del proprio voto (corrispondente a una foglia dell'albero), può verificarne l'inclusione ottenendo dall'AE il cammino di autenticazione dalla foglia alla radice ovvero la sequenza dei nodi necessari a ricalcolare la radice. Ricalcolando gli hash lungo tale cammino con SHA-256 e confrontando il risultato con la radice pubblicata e firmata dall'AE, l'elettore accerta che il cifrato del proprio voto è effettivamente presente nell'insieme su cui è stato costruito l'impegno. Questa verifica richiede un numero di passi logaritmico rispetto al numero totale di voti, in linea con il requisito di efficienza.

La verifica individuale è progettata in modo da non entrare in conflitto con la segretezza: essa accerta esclusivamente la presenza e l'integrità del proprio voto nel registro, non ne rivela il contenuto a terzi e non consente a un osservatore di associare la foglia all'identità dell'elettore. Il controllo riguarda dunque «che il voto ci sia», non «cosa contenga» né «di chi sia».

Verifica universale. Il risultato finale deve essere pubblicamente verificabile da chiunque, anche da soggetti esterni al sistema quali osservatori, commissioni indipendenti o gli stessi elettori in veste di auditor, senza il possesso di alcuna chiave privata. La verifica universale si articola su più controlli a partire dagli elementi pubblici:

- Anzitutto, chiunque può verificare la firma apposta dall'AE sulla radice dell'albero di Merkle, utilizzando la chiave pubblica dell'AE certificata dalla CA. Questo controllo accerta che la radice pubblicata è autentica, prodotta dall'AE e non sostituita da terzi dopo la chiusura delle urne. La validità della chiave pubblica dell'AE è a sua volta verificabile tramite il certificato X.509 emesso dalla CA, riconosciuta come radice di fiducia del sistema.
- In secondo luogo, poiché la radice costituisce un impegno crittografico sull'intero insieme dei voti registrati, qualunque alterazione del registro successiva alla pubblicazione produrrebbe una radice incoerente con quella firmata e sarebbe quindi rilevabile. Se un avversario alterasse anche un solo voto invaliderebbe l'impegno pubblicato.

L'insieme di questi controlli consente di accertare che la radice pubblicata è autentica e prodotta dall'AE, e che il registro dei voti non è stato manomesso dopo la chiusura delle urne. Resta invece fuori dalla portata della verifica universale, per i motivi esposti in 2.6, la dimostrazione che il conteggio aggregato pubblicato corrisponda all'effettiva decifrazione delle foglie: la verifica accerta l'integrità e l'autenticità del registro impegnato, non la correttezza del conteggio finale rispetto al contenuto cifrato. Pur con questo limite, i controlli descritti riducono significativamente la dipendenza dalla fiducia esclusiva nell'Autorità Elettorale e contribuiscono alla trasparenza complessiva del sistema.

2.8 Annullamento di una Scheda per Anomalia

Scelta progettuale: voto unico e definitivo. Nel sistema progettato si è scelto di adottare un modello a voto unico e definitivo: una volta che l'Autorità Elettorale ha accettato e registrato un voto valido, l'elettore non può sostituirlo né esprimere una nuova preferenza. Questa scelta è coerente con il requisito di unicità definito nel WP1, secondo cui ogni elettore può esprimere al più un voto valido.

La sostituzione del voto richiederebbe di consentire la sovrascrittura di una scheda già registrata, sostituendo la verifica statica basata sul registro dei token consumati con una gestione dinamica del ciclo di vita di ciascun token. Tale gestione ampliherebbe la superficie di attacco del sistema introducendo nuovi vettori di vulnerabilità, in contrasto con il principio di Economy of Mechanism adottato fin dal WP1. Inoltre, dal punto di vista crittografico, la sovrascrittura comporterebbe la rimozione o l'invalidazione di una foglia già impegnata,

operazione che una volta costruito l'albero di Merkle alla chiusura delle urne non è realizzabile senza alterare la radice e quindi l'integrità dell'intero registro.

La rinuncia alla sostituzione del voto comporta tuttavia un costo, che si sceglie di dichiarare esplicitamente: un elettore sottoposto a coercizione non ha la possibilità di rivotare successivamente in libertà per annullare il voto coartato. Si è ritenuto però che la sostituzione non costituisca una mitigazione efficace della coercizione, poiché un coercitore può comunque agire nelle fasi finali della consultazione o sottrarre le credenziali dell'elettore: il beneficio atteso non giustifica l'aumento di complessità e di superficie di attacco. Per questa ragione il protocollo adotta il voto unico e definitivo, e la presente sezione non disciplina una modifica del voto da parte dell'elettore, bensì i casi in cui una scheda non possa essere considerata valida a causa di un'anomalia rilevata durante le fasi di ricezione o di scrutinio. In tali casi la scheda viene rigettata o annullata, ma ciò avviene per effetto dei controlli del protocollo, non per volontà di sostituzione dell'elettore.

Anomalie rilevate alla ricezione. Durante la fase di votazione, l'AE sottopone ogni messaggio di voto a una sequenza di controlli prima di registrarlo. Una scheda viene rigettata, e quindi non entra a far parte dei voti registrati, in ciascuno dei seguenti casi:

- il token presentato non è un titolo autentico emesso dall'AA;
- il token risulta già presente nel registro dei token consumati, configurando un tentativo di doppio voto o un attacco di replay;
- l'impronta della chiave di integrità decifrata non coincide con quella vincolata nel token, segnalando un tentativo di riuso del token con una chiave diversa da quella del legittimo richiedente;
- il tag HMAC non è valido rispetto all'insieme di cifrato, token e nonce, segnalando un'alterazione del messaggio in transito o la provenienza da un soggetto privo della chiave legittima.

In tutti questi casi la scheda non viene registrata e non concorre alla costruzione dell'albero di Merkle. Il rigetto avviene prima della registrazione, dunque non richiede alcuna rimozione successiva di voti già acquisiti e non altera l'integrità del registro.

Anomalie rilevate in fase di scrutinio. Una scheda regolarmente registrata può comunque risultare non interpretabile al momento della decifratura, ad esempio se il contenuto in chiaro non corrisponde a una delle due opzioni valide del referendum binario. In tal caso la scheda viene classificata come non valida ai fini del conteggio. Dato che la scheda costituisce ormai una foglia dell'albero di Merkle (calcolato alla chiusura delle urne), la sua rimozione dal registro è impossibile, poiché altererebbe la radice e l'integrità dell'intera struttura. La scheda rimarrà quindi inclusa nell'impegno crittografico pubblicato, venendo semplicemente esclusa dal computo delle preferenze valide. In questo modo si preserva l'integrità del registro e la verificabilità, mantenendo traccia dell'avvenuta registrazione della scheda pur non attribuendole una preferenza valida. Si osservi che la classificazione di una scheda come non interpretabile è un'operazione che l'AE compie in fase di decifratura: come per il conteggio, essa ricade sotto il limite di verificabilità già discusso in 2.6, poiché terzi non possono accertare crittograficamente la correttezza di tale classificazione senza accedere al contenuto in chiaro delle schede. Il meccanismo resta tuttavia tracciabile, in quanto la

scheda esclusa permane come foglia dell'impegno pubblicato e non può essere rimossa di nascosto.

Coerenza con le proprietà di sicurezza. La gestione delle anomalie descritta è interamente fondata sui controlli già previsti dal protocollo e non introduce nuovi meccanismi. Il rigetto alla ricezione tutela l'unicità e l'integrità impedendo la registrazione di voti illegittimi o manomessi; la gestione delle schede non interpretabili in fase di scrutinio tutela l'integrità del registro evitando rimozioni che invaliderebbero l'impegno crittografico pubblicato. In nessun caso l'annullamento di una scheda comporta la rivelazione dell'identità dell'elettore o del contenuto di altri voti, preservando così la segretezza.

WP3 – Analisi della Sicurezza

3.1 Introduzione e metodologia di analisi

Questo capitolo analizza la sicurezza del protocollo progettato nel WP2 rispetto al modello definito nel WP1. L'analisi non introduce nuovi meccanismi: il suo scopo è verificare, proprietà per proprietà e avversario per avversario, in quale misura le scelte progettuali del WP2 soddisfano le proprietà di sicurezza dichiarate nel WP1, sotto quali assunzioni tali garanzie valgono e quale rischio residuo permane quando le assunzioni decadono.

L'analisi è condotta su tre livelli complementari:

- Il primo livello esamina ciascuna proprietà di sicurezza del WP1 e individua i meccanismi del WP2 che la realizzano, distinguendo ciò che è garantito crittograficamente da ciò che dipende da assunzioni di fiducia.
- Il secondo livello adotta la prospettiva opposta: per ciascun profilo di avversario definito nel threat model del WP1 vengono ripercorsi gli attacchi previsti, mostrando quale controllo del protocollo li rileva o li neutralizza.
- Il terzo livello, richiesto esplicitamente dalla traccia, verifica che il protocollo non ammetta modifiche ovvie capaci di migliorare alcune proprietà senza alcuna perdita in altre: per ogni variante progettuale plausibile viene mostrato il costo che essa comporterebbe su almeno un'altra proprietà, argomentando così che la soluzione adottata rappresenta un punto di compromesso consapevole e non migliorabile gratuitamente con gli strumenti considerati.

3.2 Analisi per proprietà di sicurezza

Autenticità. Il WP1 richiede che solo gli studenti aventi diritto possano partecipare al voto. Nel protocollo questa proprietà è realizzata dalla catena: autenticazione istituzionale dell'elettore presso i servizi di ateneo, verifica del diritto al voto da parte dell'AA su canale autenticato, emissione del token firmato con la chiave privata dell'AA. L'AE accetta una scheda solo se accompagnata da un token la cui firma è verificabile tramite la chiave pubblica dell'AA, certificata dalla CA con certificato X.509. Un avversario esterno privo di credenziali universitarie valide non può ottenere un token dall'AA; non può nemmeno falsificarne uno, poiché la generazione di una firma valida richiede la chiave privata dell'AA. La garanzia è dunque crittografica rispetto agli avversari esterni e vale sotto due assunzioni dichiarate nel WP1: l'onestà della CA, che non emette certificati fraudolenti, e il corretto comportamento dell'AA, che non genera token per identità non legittimate. Se l'AA è disonesta, l'autenticità decade per via interna e non per debolezza dei meccanismi: questo rischio è discusso in 3.3.

Unicità. Il WP1 richiede che ogni elettore esprima al più un voto valido. Il protocollo la realizza con un doppio controllo distribuito su due autorità distinte: l'AA mantiene il registro dei token emessi e rifiuta di rilasciarne più di uno alla stessa identità; l'AE mantiene il registro dei token consumati e rigetta qualunque scheda accompagnata da un token già

utilizzato. L'identificativo univoco incluso nel token, firmato dall'AA, è ciò che rende possibile il secondo controllo. Un elettore disonesto, per effettuare una doppia votazione, dovrebbe quindi ottenere token multipli dall'AA, violando il primo controllo, oppure riutilizzare lo stesso token, violando il secondo. Il riuso del token da parte di un avversario diverso dal legittimo titolare è inoltre impedito dal vincolo tra token e chiave di integrità: il token contiene l'impronta SHA-256 della chiave simmetrica generata dall'elettore, e l'AE scarta qualunque scheda in cui la chiave decifrata da k_{enc} non corrisponda all'impronta firmata. Il replay del medesimo messaggio di voto è infine rilevato dal nonce di sessione incluso nel calcolo del tag HMAC. La garanzia di unicità vale sotto la duplice assunzione, dichiarata nel WP1, che l'AA non emetta token multipli e che l'AE gestisca correttamente il registro dei token consumati: la distribuzione del controllo su due entità fa sì che la violazione dell'unicità richieda la disonestà di un'autorità, non un semplice attacco esterno.

Segretezza (pseudoanonimato). Il WP1 dichiara la segretezza nella forma di pseudoanonimato: nessuna singola entità deve poter ricostruire il legame identità-preferenza. Il protocollo la realizza su due piani.

Sul piano del contenuto, la scheda è cifrata con RSA-OAEP sotto la chiave pubblica dell'AE: chiunque osservi il traffico, inclusa l'AA, non può dedurre la preferenza dal cifrato. L'adozione di OAEP risponde al modello di minaccia più stringente definito nel WP1, quello a cifrato scelto, rispetto al quale lo schema deve risultare robusto. Oltre a fornire questa robustezza, il padding OAEP introduce una componente casuale decisiva per lo scenario del referendum binario: data la presenza di soli due plaintext possibili, una cifratura deterministica renderebbe banale distinguere i voti per semplice confronto dei cifrati, compromettendo l'intero sistema. La randomizzazione introdotta da OAEP garantisce invece che due voti identici producano cifrati diversi e non correlabili.

Sul piano dell'identità, la separazione AA/AE fa sì che l'AE osservi token e cifrati ma non identità, mentre l'AA conosca le identità ma non veda né i cifrati né la chiave di integrità generata dall'elettore e incapsulata esclusivamente per l'AE. Anche l'elemento k_{enc} della quadrupla non lede la separazione: è apribile solo dall'AE e non contiene riferimenti all'identità.

La pubblicazione del solo risultato aggregato, infine, evita che lo scrutinio esponga associazioni tra singole foglie e preferenze. Come dichiarato fin dal WP1, la segretezza così ottenuta è pseudoanonimato e non anonimato forte: il token è noto all'AA che lo ha emesso, e la garanzia decade in caso di collusione tra AA e AE, scenario escluso per assunzione e non per costruzione crittografica. Il rischio residuo associato a questa assunzione è analizzato in 3.3 e in 3.5.

Integrità. Il WP1 distingue l'integrità del voto in transito, l'integrità del registro e, come limite dichiarato, l'integrità del conteggio. L'analisi conferma questa tripartizione.

In transito, lo schema Encrypt-then-MAC con tag $t = HMAC_k(c \parallel token \parallel nonce)$ garantisce che qualunque alterazione del cifrato, sostituzione del token o abbinamento del token a un cifrato diverso sia rilevata dall'AE: un avversario attivo privo della chiave simmetrica non può produrre un tag valido, e non può sostituire la chiave con una propria perché l'impronta firmata nel token non corrisponderebbe. Si osservi che questa protezione vale anche nei

confronti dell'AA, modellata nel WP1 come potenzialmente disonesta: poiché la chiave di integrità non transita mai per l'AA, nemmeno l'autorità che ha emesso il token può alterare o sostituire la scheda in transito senza essere rilevata.

Nel registro, l'albero di Merkle su SHA-256 e la firma RSA dell'AE sulla radice garantiscono che, dopo la chiusura delle urne, alterazione, rimozione o inserzione anche di una sola foglia producano una radice incoerente con quella firmata e pubblicata, rendendo la manomissione rilevabile da chiunque. La firma impedisce inoltre la sostituzione della radice stessa sul luogo di pubblicazione, coerentemente con l'assunzione del WP1 secondo cui il Bulletin Board non è fidato per l'integrità dei dati.

Resta invece non garantita in modo incondizionato l'integrità del conteggio: l'AE, modellata come potenzialmente disonesta, potrebbe scartare schede prima della registrazione o pubblicare un aggregato non corrispondente alla decifrazione delle foglie. Questo limite, dichiarato nel WP1 e ribadito in 2.6, non è eliminabile con gli strumenti considerati ed è oggetto dell'analisi del rischio residuo in 3.5.

Verificabilità individuale. Ogni elettore conosce il cifrato della propria scheda e può richiedere all'AE il cammino di autenticazione dalla propria foglia alla radice: ricalcolando gli hash SHA-256 lungo il cammino e confrontando il risultato con la radice firmata, accerta l'inclusione del proprio voto con un numero di passi logaritmico nel numero di schede. L'analisi conferma che questa verifica non confligge con la segretezza: il controllo accerta la presenza della foglia, non il contenuto della preferenza, e non richiede all'elettore di rivelare la propria identità. Va però rilevato, ed è un compromesso consapevole, che il possesso del cifrato e del cammino di autenticazione costituisce per l'elettore una prova dell'esistenza della propria scheda nel registro; poiché il contenuto resta cifrato sotto la chiave dell'AE, tale prova non rivela la preferenza e non costituisce di per sé uno strumento di dimostrabilità del voto a terzi. La capacità dell'elettore di rilevare la mancata inclusione del proprio voto è inoltre l'unica mitigazione, di natura non crittografica ma statistica, contro l'esclusione selettiva di schede da parte di un'AE disonesta: la statistica ci dice che se cancelli molti voti, un numero altissimo di studenti se ne accorgerà, scatenando una protesta pubblica che farà saltare l'imbroglione.

Verificabilità universale. Chiunque, disponendo dei soli elementi pubblici (risultato aggregato, radice firmata e certificati X.509), può accertare due fatti: che la radice è autentica e prodotta dall'AE, risalendo alla CA come radice di fiducia, e che il registro impegnato non è stato manomesso dopo la pubblicazione. La verifica copre quindi l'autenticità e l'integrità dell'insieme dei voti registrati, ma non la corrispondenza tra l'aggregato pubblicato e la decifrazione delle foglie: questa resta affidata alle mitigazioni discusse in 3.5

Efficienza. Tutte le operazioni a carico dell'elettore (una cifratura RSA-OAEP della scheda, una per l'incapsulamento della chiave, un calcolo HMAC) hanno costo costante. Lo scrutinio richiede una decifrazione per scheda e la costruzione dell'albero di Merkle, entrambe lineari nel numero di voti; la verifica individuale è logaritmica; la verifica universale richiede una singola verifica di firma. Il referendum binario, in base al principio di Economy of Mechanism, mantiene la scheda a dimensione minima. Non emergono colli di bottiglia incompatibili con il requisito di efficienza del WP1; la misurazione sperimentale dei costi è demandata al WP4.

3.3 Analisi per profilo di avversario

Questa sezione ripercorre i profili del threat model definiti in 1.4.1, verificando per ciascun attacco previsto quale controllo del protocollo lo neutralizza o lo rileva, e cosa resta scoperto.

Avversario esterno (passivo e attivo). Un avversario passivo che osserva il canale tra elettore e AE vede cifrati RSA-OAEP, token e tag HMAC: nessuno di questi elementi rivela la preferenza né l'identità, e la casualità di OAEP impedisce la correlazione tra cifrati identici. Un avversario attivo che alteri il messaggio invalida il tag HMAC.

Se l'avversario provasse a iniettare un voto privo di token valido, esso verrebbe rigettato alla verifica della firma dell'AA.

Se l'avversario riproponesse un messaggio registrato, esso verrebbe rilevato dal nonce e dal registro dei token consumati.

Se l'avversario intercettasse il token di un elettore onesto e provasse a riutilizzarlo con una scheda propria, fallirebbe il confronto tra l'impronta della chiave nel token e la chiave incapsulata.

Gli attacchi crittografici nei modelli COA, KPA, CPA e CCA sono coperti dalla resistenza CCA dello schema RSA-OAEP. Resta possibile, per un avversario esterno, l'attacco Denial-of-Service contro la disponibilità del sistema: esso non rientra nei modelli crittografici formali e la sua mitigazione è di natura infrastrutturale, esterna al protocollo.

AE disonesta. È l'avversario più potente del modello. Il tentativo di violare la segretezza decifrando le schede per risalire all'identità fallisce per assenza dell'informazione necessaria: l'AE può decifrare i contenuti, ma il registro non contiene alcun riferimento all'identità, e il token non le è correlabile senza i dati dell'AA, esclusi per assunzione di non-collusione. L'alterazione o rimozione di schede dopo la chiusura delle urne è rilevabile da chiunque tramite la radice firmata; l'AE non può nemmeno ripudiare la radice pubblicata, essendo questa legata alla sua chiave privata in modo non ripudiabile. Restano i due attacchi dichiarati come limite fin dal WP1: l'esclusione di schede prima della registrazione, mitigata statisticamente dalla verifica individuale e dalla presenza di osservatori, e la pubblicazione di un aggregato non corrispondente alle foglie, non verificabile da terzi con gli strumenti del corso. Il secret sharing a soglia (t,n) riduce la superficie di questo avversario nella fase di decifratura: nessun singolo membro della Commissione di Scrutinio può decifrare autonomamente, e la decifratura è un'operazione necessariamente collegiale, il che rende la falsificazione del conteggio una collusione di almeno t soggetti anziché l'atto di una singola entità.

AA disonesta. Il tentativo di correlare token e identità per violare la segretezza richiede i dati dell'AE ed è quindi efficace solo in collusione, scenario escluso per assunzione. L'emissione di token multipli o per identità fittizie viola autenticità e unicità ed è il rischio residuo principale di questo profilo: il protocollo lo confina però alla sola fase di emissione, perché l'AA non può interferire con i voti in transito (non conosce la chiave di integrità vincolata nel token tramite impronta) né alterare il registro, protetto dalla firma dell'AE. La negazione del servizio di autenticazione a elettori legittimi resta possibile, come ogni attacco alla disponibilità, ed è mitigabile solo per via procedurale (contestazione amministrativa presso l'ateneo, che in qualità di CA e istituzione conosce l'elenco degli aventi diritto).

Elettore disonesto. Il double voting è bloccato dal doppio controllo dell'unicità del voto di AA ed AE. Il ripudio della partecipazione non danneggia il sistema: la scheda registrata permane come foglia dell'impegno pubblicato e il conteggio non dipende dal riconoscimento a posteriori dell'elettore. La dimostrabilità del voto a terzi resta invece possibile: l'elettore che conservi e consegni volontariamente la propria chiave simmetrica, il token e il cifrato fornisce a un terzo elementi per riconoscere la propria scheda; il contenuto resta cifrato sotto la chiave dell'AE, ma la volontaria cooperazione dell'elettore con un coercitore non è impedibile con gli strumenti considerati.

Coercitore/acquirente di voti. La resistenza alla coercizione non è garantibile in un ambiente di voto non fisicamente controllato: un coercitore presente al momento del voto, o in grado di esigere dall'elettore la consegna di credenziali e materiale crittografico, opera al di fuori del perimetro che gli strumenti del corso possono coprire. La scelta del voto definitivo ha qui una conseguenza che l'analisi deve rendere esplicita: l'assenza di un meccanismo di sostituzione elimina anche la possibilità, per un elettore coartato, di rivotare successivamente in libertà. Questo trade-off è discusso in 3.4 tra le modifiche valutate e scartate.

3.4 Analisi delle modifiche alternative

La traccia richiede di verificare che non esistano modifiche ovvie al protocollo capaci di migliorare alcune proprietà senza alcuna perdita in altre. In questa sezione vengono esaminate le varianti progettuali più naturali, mostrando per ciascuna il beneficio atteso e il costo che essa imporrebbe: l'esito dell'analisi è che ogni variante sposta il compromesso, senza dominare la soluzione adottata.

Firma della scheda da parte dell'elettore. Far firmare il voto all'elettore con una chiave personale certificata rafforzerebbe l'autenticità del singolo messaggio e renderebbe il voto non ripudiabile. Il costo è però fatale per la segretezza: una firma verificabile è per costruzione riconducibile al titolare della chiave, e il registro dei voti conterrebbe un identificatore forte dell'identità accanto a ciascuna scheda, annullando lo pseudoanonimato e fornendo al tempo stesso a ogni elettore una prova spendibile della propria preferenza, in favore di coercitori e acquirenti. È questa la ragione per cui la firma che protegge il registro è inserita dall'AE e non dall'elettore: l'autenticità del messaggio in transito è affidata all'HMAC con chiave vincolata al token, che fornisce autenticazione verso l'AE senza produrre prove trasferibili a terzi.

Pubblicazione delle schede decifrate anziché del solo aggregato. Pubblicare l'elenco dei voti in chiaro accanto alle foglie ridurrebbe il limite di verificabilità del conteggio: chiunque potrebbe ricontare. Il costo ricade su segretezza e coercizione: ogni elettore, conoscendo la posizione della propria foglia, potrebbe dimostrare a terzi la propria preferenza, favorendo la coercizione; inoltre la correlazione tra ordine di registrazione e tempo di votazione ecc. favorirebbe l'identificazione dell'elettore associato ad una scheda. Il protocollo adotta perciò la pubblicazione del solo aggregato, accettando il limite di verificabilità come prezzo della segretezza, in coerenza con la gerarchia di priorità del WP1, che antepone la segretezza alla verificabilità.

Sostituzione del voto prima della chiusura delle urne. Consentire la sovrascrittura del voto per garantire l'unicità finale imporrebbe una gestione dinamica dei token, al posto di una verifica statica basata su un registro dei token già consumati. Dal punto di vista ingegneristico, questa scelta contrasta con il principio di Economy of Mechanism, poiché introduce nuovi vettori di vulnerabilità nel software. Poiché questa contromisura non azzerava comunque il rischio di coercizione dato che il coercitore può agire nelle battute finali della consultazione o sequestrare le credenziali, il protocollo adotta l'approccio del voto unico e definitivo.

Eliminazione dell'HMAC affidandosi alla sola cifratura e alla firma della radice. Rimuovere il tag semplificherebbe il messaggio e ridurrebbe i costi. Il costo è la perdita dell'integrità in transito: la firma dell'AE protegge il registro dopo la registrazione, non il singolo messaggio prima che venga accettato; senza tag, un avversario attivo, inclusa un'AA disonesta, potrebbe alterare il cifrato, scambiare token tra messaggi o reimmettere schede senza essere rilevato alla ricezione. La separazione dei compiti tra HMAC (transito) e firma (registro) non è ridondante: ciascuno strumento copre una fase che l'altro non raggiunge.

Distribuzione della chiave di integrità da parte dell'AA anziché generazione da parte dell'elettore. Far distribuire la chiave simmetrica dall'AA insieme al token semplificherebbe la quadrupla, eliminando k_{enc} . Il costo è che l'AA conoscerebbe la chiave di integrità: il tag HMAC non proteggerebbe più la scheda nei confronti di un'AA disonesta, che potrebbe alterare o sostituire voti in transito producendo tag validi, in contrasto con il threat model del WP1 che modella l'AA come potenzialmente disonesta. La generazione della chiave da parte dell'elettore, con impronta vincolata nel token e trasmissione incapsulata verso la sola AE, è ciò che estende la protezione di integrità anche contro l'avversario interno.

Unificazione di AA e AE in un'unica autorità. Un'unica entità semplificherebbe l'architettura e ridurrebbe i costi di setup e comunicazione. Il costo è l'azzeramento dello pseudoanonimato: l'entità unificata disporrebbe simultaneamente di identità e voti cifrati, e la segretezza dipenderebbe interamente dalla sua onestà, riproducendo esattamente lo scenario del server centralizzato fidato che il progetto intende superare. La separazione dei poteri è il pilastro del nostro sistema di votazione elettronico e non ammette consolidamento senza perdita.

Innalzamento della soglia t fino a n . Fissare la soglia t pari al numero totale n dei membri della Commissione rafforzerebbe la riservatezza della chiave di decifratura, richiedendo l'unanimità per ricostruirla. Il costo è sulla disponibilità: una soglia pari a n rende l'indisponibilità di un solo membro sufficiente a bloccare lo scrutinio. La parametrizzazione (t, n) con t intermedio è precisamente il punto di equilibrio tra riservatezza e disponibilità: una soglia sufficientemente alta da impedire decifrazioni non autorizzate da parte di una minoranza, ma non così alta da rendere lo scrutinio fragile rispetto all'indisponibilità di singoli membri.

L'esame complessivo conferma che il protocollo progettato in WP2 non ammette, con gli strumenti considerati, modifiche che migliorino una proprietà a costo nullo: ogni variante esaminata favorisce il rispetto di determinate proprietà sfavorendo però il rispetto di proprietà con priorità maggiore.

3.5 Limiti dichiarati e rischio residuo

L'analisi consolida tre limiti, tutti già dichiarati nei capitoli precedenti, di cui si valuta qui il rischio residuo e la mitigazione.

Collusione tra AA e AE. Lo pseudoanonimato poggia sull'assunzione di non-collusione: se le due autorità combinassero i rispettivi dati, l'associazione identità–voto sarebbe ricostruibile. Il rischio non è eliminabile per via crittografica in questo modello ed è mitigato sul piano organizzativo: separazione amministrativa delle due entità rese indipendenti, trasparenza procedurale e presenza di osservatori esterni. Il danno in caso di violazione è massimo per la segretezza ma non si estende all'integrità del registro, che resta protetta dalla firma e dall'impegno pubblicato.

Integrità e verificabilità del conteggio. L'aggregato pubblicato non è dimostrabile crittograficamente coerente con la decifrazione delle foglie. Il rischio è limitato, non eliminato, dalla combinazione di verifica individuale, che rende statisticamente rilevabili le esclusioni sistematiche, decifratura collegiale tramite secret sharing a soglia, che eleva la falsificazione del conteggio da atto individuale a collusione di almeno t membri, e controllo pubblico degli osservatori. Non sono stati trattati nel corso strumenti crittografici in grado di rendere il conteggio pubblicamente dimostrabile senza rivelare i singoli voti: la loro adozione è indicabile come estensione futura del sistema, e la loro assenza è il motivo per cui il limite viene dichiarato anziché risolto.

Coercizione e compravendita del voto. In un ambiente di voto non controllato fisicamente, nessuno degli strumenti considerati distingue un voto libero da uno coartato né impedisce all'elettore di cooperare volontariamente con un acquirente. Il protocollo contiene il fenomeno evitando di produrre prove trasferibili: il registro non espone preferenze, la verifica individuale non rivela il contenuto, l'elettore non firma la scheda. Il protocollo però non può impedire la consegna volontaria di chiave, token e cifrato. Il limite è strutturale del voto elettronico remoto ed è indipendente dal protocollo adottato.

WP4 - Implementazione e Prestazioni

4.1 Obiettivo e ambiente di simulazione

Questo work package descrive l'implementazione in ambiente simulato del protocollo progettato nel WP2 e ne misura le prestazioni. Coerentemente con la traccia, l'intero sistema è realizzato come applicazione stand-alone eseguibile su un singolo computer: ogni attore (Università-CA, Autorità di Autenticazione, Autorità Elettorale, Elettori, Bulletin Board e Commissione di Scrutinio) è rappresentato da una classe software che ne incapsula stato e operazioni, mentre lo scambio di messaggi sul canale è modellato tramite chiamate di metodo.

L'implementazione è scritta in Python e si appoggia esclusivamente alla libreria cryptography per le primitive di base. Lo scenario di riferimento è un referendum binario Sì/No con sette aventi diritto, di cui sei votanti e un astenuto.

Primitive crittografiche utilizzate

L'implementazione impiega i seguenti strumenti, mappati direttamente sulle scelte del WP2:

- Cifratura del voto e incapsulamento della chiave di integrità: **RSA-2048 con padding OAEP** (MGF1 e SHA-256), con esponente pubblico 65537.
- Firme digitali (token dell'AA e radice di Merkle dell'AE): **RSA con schema PSS su SHA-256**.
- Protezione del messaggio in transito: **HMAC-SHA256 in modalità Encrypt-then-MAC**, con verifica del tag a tempo costante.
- Integrità del registro pubblico: **albero di Merkle su SHA-256**, con radice firmata dall'AE.
- Anti-replay di sessione: **schema challenge-response basato su nonce** a 128 bit.
- Gestione dell'identità delle autorità: **PKI con l'Università come Certification Authority**, che firma l'associazione (identità, chiave pubblica).
- Scrutinio collegiale: **schema di Shamir (t,n)-threshold**, realizzato tramite interpolazione di Lagrange su un campo finito primo.

4.2 Organizzazione del codice

Il codice sorgente è suddiviso in moduli specializzati, in modo da rispecchiare la separazione delle responsabilità tra gli attori definita nel WP1 e nel WP2:

Modulo	Responsabilità
crypto_primitives.py	Primitive di base: RSA-OAEP, RSA-PSS, HMAC-SHA256, SHA-256, generazione di chiavi e nonce.
pki.py	Università come CA: emissione e verifica dei certificati delle autorità.
authorities_registration.py	Autorità di Autenticazione (AA): verifica del diritto di voto, unicità, rilascio del token firmato.
authorities_electoral.py	Autorità Elettorale (AE) e Commissione di Scrutinio: raccolta voti, quattro controlli, scrutinio.
voter.py	Elettore: generazione della chiave di integrità, preparazione della quadrupla, verifica individuale.
bulletin_board.py	Registro pubblico append-only: foglie, radice di Merkle firmata, prove di inclusione.
merkle.py	Costruzione dell'albero di Merkle, generazione e verifica delle prove di inclusione.
shamir.py	Schema di Shamir (t,n): suddivisione del segreto e ricostruzione via Lagrange.
simulate.py	Esecuzione end-to-end del protocollo e batteria di scenari di attacco.
benchmark.py	Misura delle prestazioni: costo delle primitive, dimensione dei messaggi, scalabilità.

4.3 Realizzazione degli attori e del flusso operativo

1. Fase di setup (PKI e condivisione delle chiavi)

L'Università, in qualità di Certification Authority, genera la propria coppia di chiavi e firma l'associazione tra l'identità di ciascuna autorità e la sua chiave pubblica, rendendo verificabile l'autenticità delle chiavi di AA e AE. L'Autorità Elettorale genera la propria coppia di chiavi RSA. Per impedire la decifrazione unilaterale dei voti, la chiave privata dell'AE non viene mai detenuta in chiaro da un singolo soggetto: viene cifrata (AES in modalità CTR) con una chiave simmetrica derivata via SHA-256 da un segreto, e tale segreto è suddiviso con lo schema di Shamir (3,5) tra i membri della Commissione di Scrutinio. La chiave privata dell'AE torna disponibile solo quando almeno tre membri presentano congiuntamente le proprie quote.

2. Fase di autenticazione e rilascio del token

L'elettore genera autonomamente la propria chiave di integrità a 256 bit e ne calcola l'impronta SHA-256, che invia all'AA insieme alla richiesta di autenticazione. L'AA verifica che il richiedente sia un avente diritto e che non abbia già ottenuto un token, quindi emette un token firmato (RSA-PSS) contenente uno pseudonimo casuale, slegato dall'identità reale, e l'impronta della chiave di integrità. È importante notare che l'AA firma l'impronta senza conoscere mai la chiave in chiaro: ciò sostiene lo pseudoanonimato sotto l'assunzione di non-collusione tra AA e AE.

3. Fase di voto (l'elettore)

L'elettore richiede all'AE un nonce di sessione e prepara la quadrupla di voto:

- c — la preferenza Sì/No cifrata con RSA-OAEP sotto la chiave pubblica dell'AE;
- k_{enc} — la propria chiave di integrità incapsulata con RSA-OAEP sotto la chiave pubblica dell'AE;
- tag — il codice HMAC-SHA256 calcolato in modalità Encrypt-then-MAC sulla concatenazione ($c \parallel token \parallel nonce$);
- $token$ — il token firmato ricevuto dall'AA.

La quadrupla così ottenuta viene trasmessa all'AE. Si osservi che la chiave di integrità è generata dall'elettore e trasportata cifrata sotto la chiave pubblica dell'AE: in questo modo l'AA non entra mai in possesso della chiave che protegge l'integrità del messaggio.

4. Fase di ricezione e validazione (l'AE)

Ricevuta la quadrupla, e dopo aver verificato che il nonce sia tra quelli effettivamente emessi nella sessione, l'AE esegue in sequenza quattro controlli; il voto è accettato solo se tutti hanno esito positivo:

- **Controllo 1** — la firma del token è valida ed è stata prodotta dall'AA;
- **Controllo 2** — il token non risulta già consumato (unicità lato AE);
- **Controllo 3** — l'impronta SHA-256 della chiave di integrità decifrata da k_{enc} coincide con quella firmata nel token (legame token-chiave);
- **Controllo 4** — il tag HMAC è valido sulla concatenazione ($c \parallel token \parallel nonce$).

Superati i controlli, il token viene marcato come consumato, il nonce viene ritirato e la foglia (c, tag, pseudonimo) è aggiunta al Bulletin Board. Alla chiusura delle urne, l'AE calcola la radice dell'albero di Merkle costruito sulle foglie e la firma con la propria chiave privata.

5. Scrutinio e verifiche

La Commissione di Scrutinio, presentando almeno tre quote, ricostruisce il segreto tramite interpolazione di Lagrange, deriva la chiave AES, recupera la chiave privata dell'AE e decifra i voti, pubblicando esclusivamente il conteggio aggregato Sì/No. Le eventuali schede non interpretabili vengono conteggiate come nulle senza essere rimosse dal registro, per non alterare l'albero di Merkle. La verifica individuale consente a ciascun elettore di rintracciare la propria foglia e controllarne la prova di inclusione di Merkle rispetto alla radice firmata; la verifica universale consente a chiunque di ricostruire l'intero albero dalle foglie pubbliche e di verificare la firma dell'AE sulla radice.

4.4 Risultati della simulazione end-to-end

Il file `simulate.py` riproduce lo scenario referendario con sette aventi diritto (sei votanti e un astenuto). L'esecuzione completa il flusso dal setup allo scrutinio: i sei voti sono registrati correttamente sul Bulletin Board, la radice di Merkle viene pubblicata e firmata, tutte le verifiche individuali hanno esito positivo e la verifica universale conferma la firma sulla radice. Lo scrutinio, autorizzato da tre quote su cinque, produce esattamente il risultato atteso di quattro Sì e due No. La simulazione mostra inoltre, sui valori reali, che due cifrature della stessa preferenza producono crittogrammi diversi, a conferma della natura randomizzata di RSA-OAEP.

Scenari di attacco respinti

La simulazione include una batteria di scenari di attacco, ciascuno mirato a sollecitare una specifica proprietà di sicurezza. In tutti i casi il sistema respinge l'attacco:

Attacco simulato	Contromisura che lo respinge
Registrazione di un non-avente-diritto	L'AA rifiuta: l'identità non è nell'elenco degli aventi diritto.
Doppia richiesta di token	L'AA rifiuta: l'elettore ha già ottenuto un token (unicità lato AA).
Token contraffatto (firma non valida)	Controllo 1 dell'AE: la firma dell'AA sul token non è valida.
Manomissione del cifrato in transito	Controllo 4 dell'AE: il tag HMAC non è più valido.
Riuso di un token già consumato	Controllo 2 dell'AE: il token risulta già speso (unicità lato AE).
Furto del token con chiave propria	Controllo 3 dell'AE: l'impronta della chiave non coincide con quella firmata.
Replay con nonce non emesso	L'AE rifiuta: il nonce non è tra quelli aperti nella sessione.
Alterazione di una foglia pubblicata	Verifica universale: la radice ricalcolata non corrisponde alla firma.
Scrutinio sotto la soglia (2 quote)	La Commissione rifiuta: il segreto non è ricostruibile con meno di t quote.

4.5 Prestazioni

Le misure prestazionali sono prodotte dal file `benchmark.py` tramite il timer ad alta risoluzione `perf_counter`, mediando ciascuna operazione su più ripetizioni. I valori che seguono provengono da un'esecuzione su una macchina di sviluppo e hanno valore indicativo: ciò che conta è l'ordine di grandezza e l'andamento, non il dato puntuale, che varia con l'hardware.

Costo computazionale delle primitive

La generazione delle coppie RSA-2048 è l'operazione più onerosa, ma avviene una sola volta in fase di setup. Tutte le operazioni a regime, eseguite a ogni voto o in fase di verifica, restano ampiamente sotto il millisecondo:

Operazione	Tempo medio (ms)	Frequenza
Generazione coppia RSA-2048	55.4	una tantum (setup)
Cifratura voto (RSA-OAEP)	0.031	per voto
Incapsulamento <code>k_mac</code> (RSA-OAEP)	0.031	per voto
Decifratura RSA-OAEP	0.659	per voto (scrutinio)
Firma radice (RSA-PSS)	0.658	una tantum (chiusura)
Verifica firma (RSA-PSS)	0.035	per controllo
HMAC-SHA256 (calcolo tag)	0.006	per voto
HMAC-SHA256 (verifica tag)	0.005	per voto
Impronta SHA-256 della chiave	0.002	per voto
Generazione nonce	0.001	per sessione
Shamir split (3,5)	0.009	una tantum (setup)
Shamir recover (3 quote)	0.666	una tantum (scrutinio)

Dimensione dei messaggi

La quadrupla trasmessa dall'elettore all'AE ha dimensione fissa e compatta, indipendente dal numero di elettori:

Componente	Dimensione
<code>c</code> (voto cifrato, RSA-2048)	256 byte
tag (HMAC-SHA256)	32 byte
token (pseudonimo)	16 byte
<code>k_enc</code> (chiave incapsulata, RSA-2048)	256 byte
Quadrupla totale	560 byte

I 256 byte aggiuntivi dovuti all'incapsulamento della chiave di integrità rappresentano il costo, deliberatamente accettato, per evitare che la chiave HMAC sia distribuita tramite l'AA: è il prezzo della salvaguardia dello pseudoanonimato discussa nel WP2.

Scalabilità

L'analisi al crescere del numero di elettori mostra un andamento lineare ($O(N)$) per le fasi di registrazione, voto e scrutinio, mentre la verifica universale rimane nell'ordine del millisecondo grazie alle proprietà dell'albero di Merkle:

Elettori	Voto+reg. (ms)	Spoglio (ms)	Verifica univ. (ms)
10	15.4	49.1	0.14
50	75.7	73.3	0.29
100	150.6	110.1	0.52
200	298.9	174.7	0.90

I tempi confermano che il protocollo è utilizzabile senza costi o latenze eccessive: la fase di voto cresce linearmente perché è dominata dalle operazioni crittografiche per elettore, mentre la verifica del registro resta sub-millisecondica anche con un campione esteso a duecento elettori.

4.6 Limiti dell'implementazione

Ai fini di un'analisi onesta, si evidenziano i limiti propri del prototipo: limiti relativi alle proprietà di sicurezza del protocollo, lo pseudoanonimato fondato sull'assunzione di non-collusione tra AA e AE e l'assenza di una prova crittografica che il conteggio aggregato corrisponda alla decifrazione delle foglie.

- **Semplificazione dei certificati X.509.** Il certificato è modellato come la firma RSA della CA sull'associazione (identità, chiave pubblica). Vengono omessi i campi accessori dello standard (numero di serie, periodo di validità, estensioni, revoca), mantenendo però la funzione sostanziale: l'autenticità della chiave pubblica garantita dalla firma dell'autorità.
- **Protezione Shamir applicata indirettamente.** Lo schema di Shamir non frammenta direttamente l'esponente privato RSA dell'AE, ma il segreto da cui si deriva la chiave AES con cui tale chiave è cifrata. La garanzia di decifrazione collegiale resta preservata: la chiave privata dell'AE è inaccessibile finché non si ricompongono almeno t quote, e nessun membro può ottenerla da solo.
- **Canale di comunicazione modellato.** Lo scambio di messaggi tra le parti è reso tramite chiamate di metodo anziché connessioni di rete reali; le proprietà crittografiche del protocollo, oggetto della valutazione, non dipendono dal mezzo di trasporto e sono interamente riprodotte.